

CYBER THREAT INTELLIGENCE REPORT

두 개의 동시 위협: 호스팅 인프라 장악과 자가 전파 공급망 웹

LiteSpeed cPanel 플러그인 CVSS 10.0 RCE (CVE-2026-48172) · Mini Shai-Hulud npm 웹 신규 웨이브 (TeamPCP)

활성 익스플로잇 진행 중 · 한국 호스팅 개발 생태계 직접 노출 · OSINT 기반 방어 분석

리포트 ID	CTI-2026-0524-DUALTHREAT
발행일	2026-05-24 (KST)
분류 (TLP)	TLP:GREEN — 커뮤니티 내 자유 공유 가능 (출처 표기 필수)
심각도	CRITICAL — 활성 익스플로잇 + 자가 전파 웹 (즉시 대응)
대상 위협	① CVE-2026-48172 (LiteSpeed User-End cPanel Plugin, CVSS 10.0) ② Mini Shai-Hulud npm 웹 5월 신규 2개 웨이브 (TeamPCP)
위협 행위자	TeamPCP (별칭: DeadCatx3 · PCPcat · ShellForce · CipherForce) / ② 한정
프레임워크	MITRE ATT&CK · NIST SP 800-61 · NIST SP 800-207 (Zero Trust)
작성	Dennis Kim (김호광) · Independent Threat Intelligence Analyst · gameworker@gmail.com

요약 (Executive Summary)

2026년 5월, 서로 무관해 보이지만 동일한 구조적 교훈을 공유하는 두 개의 고위험 위협이 동시에 활성화되었다. 두 위협 모두 '신뢰받는 기본 권한'과 '신뢰받는 자동화 파이프라인'을 공격자가 합법적으로 탈취해 권한을 상승시키는 형태이며, 한국의 웹호스팅 산업과 개발자 생태계에 직접적인 노출을 발생시킨다.

- **위협 ① — LiteSpeed cPanel 플러그인 RCE (CVE-2026-48172, CVSS 10.0):** 공유 호스팅에서 모든 cPanel 사용자(공격자·탈취 계정 포함)가 lsws.redisAble JSON-API 한 번의 호출만으로 root 권한 임의 스크립트 실행이 가능하다. 인증 우회·레이스 컨디션이 불필요하며 이미 해킹 시장에서 자동화 툴이 판매되며 활발히 악용 중이다.
- **위협 ② — Mini Shai-Hulud npm 웹 신규 웨이브 (TeamPCP):** 5월 두 차례의 새 웨이브 중 하나는 자격증명이 전혀 필요 없는 초기 접근(credential-free) 기법을, 다른 하나는 역대 Shai-Hulud 웹 최고의 시간당 패키지 생성 수를 기록했다. 4월의 @bitwarden/cli 2026.4.0 위장 패키지는 설치 즉시 클라우드·CI/CD·개발자 워크스테이션 자격증명을 탈취하고 피해자가 게시 가능한 모든 npm 패키지로 자가 전파한다.
- **공통 교훈:** 두 사건 모두 '훔친 비밀번호'가 아니라 '정당하게 부여된 권한·신뢰'를 악용한다. 따라서 자격증명 회전만으로는 방어가 불완전하며, 최소 권한 원칙(Zero Trust)과 신뢰 경계 재설계가 핵심 대응이 필요하다는 것을 다시 일깨운다.

핵심 판단 (Key Judgments)

#	판단	신뢰도
KJ-1	CVE-2026-48172는 권한 할당 오류(Incorrect Privilege Assignment) 유형으로, 공유 호스팅 환경에서 단일 악성 또는 탈취 테넌트가 서버 전체(root) 장악으로 직행할 수 있다. 활성 악용이 공급사에 의해 확인되었다.	High
KJ-2	한국은 cPanel/WHM + LiteSpeed 조합을 사용하는 중소 웹호스팅·리셀러가 다수 존재하므로, 단일 서버에 수백 테넌트가 상주하는 공유 호스팅의 구조적 특성상 국내 노출 가능성이 높다.	Medium
KJ-3	Mini Shai-Hulud의 'credential-free 초기 접근'은 OIDC 토큰을 러너 메모리에서 직접 추출·교환해 npm 게시 권한을 획득하므로, 정당한 릴리스 파이프라인이 유효한 SLSA 출처증명(provenance)을 달고 악성 패키지를 게시한다. 출처증명만으로는 안전을 보장할 수 없다.	High
KJ-4	토큰 폐기(revocation)에 반응해 사용자 홈 디렉터리를 파괴(rm -rf ~/)하는 실패·안전 장치가 관측되었으므로, '호스트 격리 후 자격증명 폐기'라는 통상 대응이 오히려 데이터 파괴를 유발할 수 있다.	High
KJ-5	모방(copypcat) 활동의 증가로 향후 TeamPCP 귀속 판단의 정확도가 낮아지고 있어, 단일 행위자 가정보다 'Shai-Hulud 계열 TTP' 단위의 방어가 더 안정적이다.	Medium

1. LiteSpeed cPanel 플러그인 RCE — CVE-2026-48172

1.1 개요

CVE	CVE-2026-48172
CVSS	10.0 (CRITICAL · 최고 심각도)
취약점 유형	권한 할당 오류 (Incorrect Privilege Assignment) → 권한 상승 / root RCE
영향 제품	LiteSpeed User-End cPanel Plugin (사용자단 플러그인). WHM 플러그인은 직접 영향 없음
영향 버전	v2.3 ~ v2.4.4 (v2.4.5 미만 전체)
수정 버전	v2.4.5에서 수정 / 권장 최소 버전 v2.4.7 (WHM 플러그인 v5.3.1.0 번들)
악용 상태	야생에서 활성 익스플로잇 확인 (2026-05, 0-day)
발견자	보안 연구자 David Strydom

1.2 기술 분석

- 인증 우회·레이스 컨디션이 불필요하다. 유효한 cPanel 세션을 가진 상태에서 특정 파라미터 값을 담은 단일 비정상 API 호출만으로 root 권한 상승이 성립한다.
- Redis 활성화/비활성화 기능의 처리 미흡(mishandling)이 핵심 결함으로, 사용자 입력이 상승된 권한 컨텍스트로 그대로 전달된다.

- 공유 호스팅 환경에서 특히 치명적이다 — 단일 서버에 수백 테넌트가 이미 유효한 cPanel 세션을 보유하므로, 악성 테넌트 또는 이미 탈취된 계정 하나가 서버 전체 장악(full server takeover)으로 피벗할 수 있다.

1.3 영향 평가

차원	영향
기밀성	동일 서버 내 모든 테넌트의 파일·DB·키 자료 노출 (root 접근)
무결성	웹셸·백도어·크립토마이너 설치, 콘텐츠 변조, 공급망 위터링홀 가능
가용성	서버 전체 다운·랜섬·로그 삭제로 인한 사고 분석 방해
확산성	리셀러·멀티테넌트 호스팅에서 한 서버 침해가 다수 고객사로 연쇄 확산

1.4 탐지 (Detection)

LiteSpeed가 제공한 침해 지표(IoC) 점검 명령. 출력이 없으면 미악용, 출력이 있으면 해당 IP를 검증·차단하고 사후 침해 활동을 조사한다.

```
grep -rE "cpanel_jsonapi_func=redisAble" /var/cpanel/logs /usr/local/cpanel/logs/2>/dev/null
```

1.5 대응 및 완화 (Remediation)

우선	조치
1	즉시 LiteSpeed WHM Plugin v5.3.1.0(cPanel 플러그인 v2.4.7 번들)으로 업그레이드. 추가 공격 벡터 하드닝 포함.
2	즉시 패치가 불가하면 사용자단 플러그인 제거(완화책): /usr/local/lsws/admin/misc/lscmctl cpanelplugin --uninstall
3	1.4의 grep 명령으로 악용 흔적 점검 → 의심 IP 차단, 시스템 로그 정밀 분석.
4	침해 의심 시 서버 비밀번호·API 토큰·SSH 키 전면 회전, 웹셸·예약작업(cron)·신규 사용자 점검.
5	동일 서버 5월 권고 누적 점검: pre-auth 우회 CVE-2026-41940(CVSS 9.8) 등 cPanel 생태계 다발 권고 병행 확인.

2. Mini Shai-Hulud npm 웹 신규 웨이브 (TeamPCP)

2.1 개요

캠페인	Mini Shai-Hulud (Shai-Hulud 계열 4세대 변종)
위협 행위자	TeamPCP (별칭 DeadCatx3 · PCPcat · ShellForce · CipherForce), 금전 동기, 2024년 이후 활동
주요 사건	@bitwarden/cli 2026.4.0 위장 패키지 (4월) TanStack OIDC 하이재킹 웨이브 (5/11, CVE-2026-45321) AntV 등 5/19 22분간 300+ 버전 자동 게시 웨이브
탐지 보안기업	Endor Labs · Wiz · SafeDep · Socket · StepSecurity · Snyk · Unit 42 · Akamai 외
관련 CVE	CVE-2026-45321 (TanStack 웨이브 한정 할당)

2.2 @bitwarden/cli 위장 패키지 분석

- 실행 경로 변조 → 악성 로더 실행 → GitHub 에서 Bun 아카이브 다운로드·추출 → JavaScript 페이로드 실행.
- C2 우회: github.com 트래픽은 보안 도구에서 통상 차단되지 않으며 행위자 소유 도메인으로 역추적되지 않는다. 탈취 데이터는 비대칭 암호화로 은닉.

2.3 credential-free 초기 접근 — 신규 기법

이전 모든 웨이브는 '훔친 자격증명'으로 시작했으나, 이번 신규 웨이브는 그렇지 않다. 공격 흐름은 다음과 같다.

단계	행위
1	TanStack GitHub Actions CI의 PR 워크플로 오설정 악용. 포크 PR이 베이스 저장소 캐시에 쓰기 권한을 가진 워크플로를 트리거.
2	공격자 코드가 캐시를 오염시키고 잠복(약 8시간). 정식 메인테이너의 머지가 표준 릴리스 워크플로를 발동시키며 오염 캐시 로딩.
3	웹이 러너 메모리에서 OIDC 토큰을 직접 스크래핑 → npm 토큰 교환 엔드포인트로 게시 자격증명 획득.
4	npm 토큰이 '훔쳐진' 적이 없고 게시 워크플로 자체도 손상되지 않아 공격이 보이지 않으며, 유효한 SLSA Build Level 3 출처증명을 획득. (5/11 19:20-19:26 UTC, @tanstack 42개 패키지에 84개 악성 버전 게시)

2.4 파괴적 실패-안전 장치 (Wiper)

⚠ **대응 경고:** '호스트 격리 후 자격증명 즉시 폐기'라는 통상 1차 대응이 와이퍼를 발동시킬 수 있다. 로컬에 파괴적 실패-안전 장치가 무장되어 있지 않음을 확인하기 전까지 토큰 폐기·격리를 신중히 단계화해야 한다.

2.5 MITRE ATT&CK 매핑

전술	기법 (ID)	본 캠페인 적용
Initial Access	Supply Chain Compromise (T1195.002)	오염된 npm/PyPI 패키지 배포
Execution	npm preinstall hook / __init__.py 인젝션	설치 시 자동 페이로드 실행
Credential Access	Steal Application Access Token (T1528)	러너 메모리 OIDC 토큰 추출·교환
Persistence	Scheduled Task/Daemon (T1543)	gh-token-monitor (LaunchAgent/systemd)
Exfiltration	Exfil over Web Service (T1567)	GitHub dead-drop · Session 메신저 · 타이포스쿼트 도메인
Impact	Data Destruction (T1485)	토큰 폐기 시 rm -rf ~/ 와이퍼
Propagation	Lateral Tool Transfer (웜)	피해자 게시 권한 패키지 전부 재게시

2.6 침해 지표 (IoC) 및 헌팅

- 탈취 채널 / C2: git-tanstack[.]com (타이포스쿼트), filev2.getsession.org, api.masscan.cloud, git-tanstack.com 호스팅 transformers.pyz 드로퍼.
- 노출 윈도: 2026-05-11T19:20Z 이후 CI 실행 감사. 예기치 않은 npm publish 이벤트 및 상기 도메인 아웃바운드 연결 점검.
- npm token list 로 미인지 토큰 폐기. 단, **유효한 SLSA 출처증명은 안전의 증거가 아니다** — 페이로드 SHA-256 해시로 대조할 것.
- 하류 전파 점검: 노출 윈도 중 CI 에서 게시된 자사 패키지가 있다면 해당 버전도 오염 가능. 조직 GitHub 에서 의심 저장소·워크플로 변경 헌팅.

3. 한국 관점 및 통합 권고

3.1 한국 생태계 노출

대상	노출 양상
웹호스팅·리셀러	cPanel/WHM + LiteSpeed 조합을 쓰는 국내 중소 호스팅·리셀러 다수. 공유 서버 한 대 침해 시 입주 고객사 연쇄 피해 (위협 ①)
개발사·스타트업	npm/PyPI 의존성과 GitHub Actions CI/CD를 광범위하게 사용. OIDC 신뢰 오설정 시 자가 전파 웹에 노출 (위협 ②)
Web3·핀테크	프론트엔드·지갑 SDK가 npm 공급망에 의존. 빌드 파이프라인 오염이 사용자 자산 리스크로 직결
공공·금융	외주 개발·패키지 재사용 관행상 간접 공급망 노출. KISA·금융보안원 권고 모니터링 필요

3.2 통합 우선순위 권고

#	조치	대상 위협
1	LiteSpeed cPanel 플러그인 v2.4.7+ 즉시 업그레이드 또는 사용자단 플러그인 제거	① 즉시
2	redisAble 로그 grep 점검 및 공유 서버 침해 헌팅	① 24h
3	GitHub Actions OIDC 신뢰 범위 최소화(워크플로·브랜치 한정), 포크 PR 캐시 쓰기 차단	② Zero Trust
4	의존성 핀 고정·락파일 검증, SHA-256 해시 대조(SLSA 출처증명 맹신 금지)	② 공급망
5	와이퍼 위험 인지: 토큰 폐기·격리를 신중히 단계화, 백업 선확보 후 대응	② IR 절차
6	CI/CD 자격증명을 특권 토큰으로 취급 — 스코프 한정·정기 회전·게시 이벤트 감사 로깅	①② 공통

3.3 종합 — '권한과 신뢰의 악용'이라는 공통 구조

두 위협은 표면적으로 무관하나 동일한 구조를 공유한다. CVE-2026-48172는 '모든 사용자에게 기본 노출된 권한'을, Mini Shai-Hulud는 '자동화 파이프라인에 부여된 신뢰(OIDC)'를 각각 합법적으로 악용한다. 어느 쪽도 전통적 의미의 '침입'이나 '비밀번호 탈취'에 의존하지 않는다.

따라서 방어 핵심은 자격증명 회전을 넘어 신뢰 경계의 재설계에 있다. 최소 권한 원칙(NIST SP 800-207 Zero Trust), 기본 노출 권한의 축소, 자동화 신뢰의 명시적 스코핑, 그리고 출처증명·서명만으로 안전을 단정하지 않는 검증 태세가 두 위협 모두에 대한 근본 대응이 된다.

부록 A. 참고 자료 (References)

1. **The Hacker News.** "LiteSpeed cPanel Plugin CVE-2026-48172 Exploited to Run Scripts as Root." <https://thehackernews.com/2026/05/litespeed-cpanel-plugin-cve-2026-48172.html>
2. **GBHackers.** "LiteSpeed cPanel Plugin 0-Day Exploited for Server Root Access." <https://gbhackers.com/litespeed-cpanel-plugin-0-day-exploited/>
3. **Cyber Security News.** "LiteSpeed cPanel Plugin 0-Day Exploited in the wild." <https://cybersecuritynews.com/litespeed-cpanel-plugin-0-day-exploited/>
4. **Unit 42 (Palo Alto).** "The npm Threat Landscape: Attack Surface and Mitigations (Updated May 21)." <https://unit42.paloaltonetworks.com/monitoring-npm-supply-chain-attacks/>
5. **Akamai.** "Mini Shai-Hulud: The Worm Returns and Goes Public." <https://www.akamai.com/blog/security-research/mini-shai-hulud-worm-returns-goes-public>
6. **Wiz.** "Mini Shai-Hulud Strikes Again: TanStack + more npm Packages Compromised." <https://www.wiz.io/blog/mini-shai-hulud-strikes-again-tanstack-more-npm-packages-compromised>
7. **StepSecurity.** "TeamPCP's Mini Shai-Hulud Is Back." <https://www.stepsecurity.io/blog/mini-shai-hulud-is-back-a-self-spreading-supply-chain-attack-hits-the-npm-ecosystem>
8. **Snyk.** "TanStack npm Packages Hit by Mini Shai-Hulud." <https://snyk.io/blog/tanstack-npm-packages-compromised/>
9. **SecurityWeek.** "Bitwarden NPM Package Hit in Supply Chain Attack." <https://www.securityweek.com/bitwarden-npm-package-hit-in-supply-chain-attack/>
10. **Tenable.** "Mini Shai-Hulud Supply Chain Attack CVE-2026-45321 FAQ." <https://www.tenable.com/blog/mini-shai-hulud-frequently-asked-questions>

부록 B. 면책 조항 (Disclaimer)

1. 본 리포트는 공개된 OSINT 자료와 언론·벤더 보안 권고를 기반으로 한 독립적 분석이며, 관련 조직·기관·기업의 공식 입장을 대변하지 않는다.
2. 내용은 교육·방어·연구·정책 수립 목적으로만 사용되어야 하며, 공격·침해·불법 활동에 사용하는 것을 엄격히 금지한다.
3. IoC·취약점 정보는 발행 시점(2026-05-24) 기준이며, 실제 적용 전 반드시 최신 상태를 재확인해야 한다.
4. 저자는 본 자료의 직접적·간접적 사용으로 발생하는 어떠한 손해에 대해서도 책임지지 않는다.